NIST Special Publication 800-53
Revision 5

Security and Privacy Controls for Information Systems and Organizations

JOINT TASK FORCE

This publication is available free of charge from:
https://doi.org/10.6028/NIST.SP.800-53r5

National Institute of Standards and Technology
U.S. Department of Commerce

Executive Summary

As we push computers to "the edge," building an increasingly complex world of connected information systems and devices, security and privacy will continue to dominate the national dialogue. In its 2017 report, *Task Force on Cyber Deterrence* [DSB 2017], the Defense Science Board (DSB) provides a sobering assessment of the current vulnerabilities in the U.S. critical infrastructure and the information systems that support mission-essential operations and assets in the public and private sectors.

> *"…The Task Force notes that the cyber threat to U.S. critical infrastructure is outpacing efforts to reduce pervasive vulnerabilities, so that for the next decade at least the United States must lean significantly on deterrence to address the cyber threat posed by the most capable U.S. adversaries. It is clear that a more proactive and systematic approach to U.S. cyber deterrence is urgently needed…"*

There is an urgent need to further strengthen the underlying information systems, component products, and services that the Nation depends on in every sector of the critical infrastructure—ensuring that those systems, components, and services are sufficiently trustworthy and provide the necessary resilience to support the economic and national security interests of the United States. This update to NIST Special Publication (SP) 800-53 responds to the call by the DSB by embarking on a proactive and systemic approach to develop and make available to a broad base of public and private sector organizations a comprehensive set of safeguarding measures for all types of computing platforms, including general purpose computing systems, cyber-physical systems, cloud-based systems, mobile devices, Internet of Things (IoT) devices, weapons systems, space systems, communications systems, environmental control systems, super computers, and industrial control systems. Those safeguarding measures include implementing security and privacy controls to protect the critical and essential operations and assets of organizations and the privacy of individuals. The objectives are to make the information systems we depend on more penetration-resistant, limit the damage from attacks when they occur, make the systems cyber-resilient and survivable, and protect individuals' privacy.

Revision 5 of this foundational NIST publication represents a multi-year effort to develop the next generation of security and privacy controls that will be needed to accomplish the above objectives. It includes changes to make the controls more usable by diverse consumer groups (e.g., enterprises conducting mission and business functions; engineering organizations developing information systems, IoT devices, and systems-of-systems; and industry partners building system components, products, and services). The most significant changes to this publication include:

- Making the controls more *outcome-based* by removing the entity responsible for satisfying the control (i.e., information system, organization) from the control statement;
- Integrating information security and privacy controls into a seamless, consolidated control catalog for information systems and organizations;
- Establishing a new supply chain risk management control family;
- Separating control selection *processes* from the *controls*, thereby allowing the controls to be used by different communities of interest, including systems engineers, security architects, software developers, enterprise architects, systems security and privacy engineers, and mission or business owners;

This publication is available free of charge from: https://doi.org/10.6028/NIST.SP.800-53r5

Controls can be viewed as descriptions of the safeguards and protection capabilities appropriate for achieving the particular security and privacy objectives of the organization and reflecting the protection needs of organizational stakeholders. Controls are selected and implemented by the organization in order to satisfy the system requirements. Controls can include administrative, technical, and physical aspects. In some cases, the selection and implementation of a control may necessitate additional specification by the organization in the form of *derived requirements* or instantiated control parameter values. The derived requirements and control parameter values may be necessary to provide the appropriate level of implementation detail for particular controls within the SDLC.

2.2 CONTROL STRUCTURE AND ORGANIZATION

Security and privacy controls described in this publication have a well-defined organization and structure. For ease of use in the security and privacy control selection and specification process, controls are organized into 20 *families*.[25] Each family contains controls that are related to the specific topic of the family. A two-character identifier uniquely identifies each control family (e.g., *PS* for Personnel Security). Security and privacy controls may involve aspects of policy, oversight, supervision, manual processes, and automated mechanisms that are implemented by systems or actions by individuals. Table 1 lists the security and privacy control families and their associated family identifiers.

TABLE 1: SECURITY AND PRIVACY CONTROL FAMILIES

ID	FAMILY	ID	FAMILY
AC	Access Control	PE	Physical and Environmental Protection
AT	Awareness and Training	PL	Planning
AU	Audit and Accountability	PM	Program Management
CA	Assessment, Authorization, and Monitoring	PS	Personnel Security
CM	Configuration Management	PT	PII Processing and Transparency
CP	Contingency Planning	RA	Risk Assessment
IA	Identification and Authentication	SA	System and Services Acquisition
IR	Incident Response	SC	System and Communications Protection
MA	Maintenance	SI	System and Information Integrity
MP	Media Protection	SR	Supply Chain Risk Management

Families of controls contain base controls and control enhancements, which are directly related to their base controls. Control enhancements either add functionality or specificity to a base control or increase the strength of a base control. Control enhancements are used in systems and environments of operation that require greater protection than the protection provided by the base control. The need for organizations to select and implement control enhancements is due to the potential adverse organizational or individual impacts or when organizations require additions to the base control functionality or assurance based on assessments of risk. The

[25] Of the 20 control families in NIST SP 800-53, 17 are aligned with the minimum security requirements in [FIPS 200]. The Program Management (PM), PII Processing and Transparency (PT), and Supply Chain Risk Management (SR) families address enterprise-level program management, privacy, and supply chain risk considerations pertaining to federal mandates emergent since [FIPS 200].

This publication is available free of charge from: https://doi.org/10.6028/NIST.SP.800-53r5

AC-2 ACCOUNT MANAGEMENT

Control:

a. Define and document the types of accounts allowed and specifically prohibited for use within the system;

b. Assign account managers;

c. Require [*Assignment: organization-defined prerequisites and criteria*] for group and role membership;

d. Specify:

1. Authorized users of the system;

2. Group and role membership; and

3. Access authorizations (i.e., privileges) and [*Assignment: organization-defined attributes (as required)*] for each account;

e. Require approvals by [*Assignment: organization-defined personnel or roles*] for requests to create accounts;

f. Create, enable, modify, disable, and remove accounts in accordance with [*Assignment: organization-defined policy, procedures, prerequisites, and criteria*];

g. Monitor the use of accounts;

h. Notify account managers and [*Assignment: organization-defined personnel or roles*] within:

1. [*Assignment: organization-defined time period*] when accounts are no longer required;

2. [*Assignment: organization-defined time period*] when users are terminated or transferred; and

3. [*Assignment: organization-defined time period*] when system usage or need-to-know changes for an individual;

i. Authorize access to the system based on:

1. A valid access authorization;

2. Intended system usage; and

3. [*Assignment: organization-defined attributes (as required)*];

j. Review accounts for compliance with account management requirements [*Assignment: organization-defined frequency*];

k. Establish and implement a process for changing shared or group account authenticators (if deployed) when individuals are removed from the group; and

l. Align account management processes with personnel termination and transfer processes.

Discussion: Examples of system account types include individual, shared, group, system, guest, anonymous, emergency, developer, temporary, and service. Identification of authorized system users and the specification of access privileges reflect the requirements in other controls in the security plan. Users requiring administrative privileges on system accounts receive additional scrutiny by organizational personnel responsible for approving such accounts and privileged access, including system owner, mission or business owner, senior agency information security officer, or senior agency official for privacy. Types of accounts that organizations may wish to prohibit due to increased risk include shared, group, emergency, anonymous, temporary, and guest accounts.

This publication is available free of charge from: https://doi.org/10.6028/NIST.SP.800-53r5

SA-12 SUPPLY CHAIN PROTECTION

[Withdrawn: Incorporated into SR Family.]

Control Enhancements:

(1) SUPPLY CHAIN PROTECTION | ACQUISITION STRATEGIES / TOOLS / METHODS
[Withdrawn: Moved to SR-5.]

(2) SUPPLY CHAIN PROTECTION | SUPPLIER REVIEWS
[Withdrawn: Moved to SR-6.]

(3) SUPPLY CHAIN PROTECTION | TRUSTED SHIPPING AND WAREHOUSING
[Withdrawn: Incorporated into SR-3.]

(4) SUPPLY CHAIN PROTECTION | DIVERSITY OF SUPPLIERS
[Withdrawn: Moved to SR-3(1).]

(5) SUPPLY CHAIN PROTECTION | LIMITATION OF HARM
[Withdrawn: Moved to SR-3(2).]

(6) SUPPLY CHAIN PROTECTION | MINIMIZING PROCUREMENT TIME
[Withdrawn: Incorporated into SR-5(1).]

(7) SUPPLY CHAIN PROTECTION | ASSESSMENTS PRIOR TO SELECTION / ACCEPTANCE / UPDATE
[Withdrawn: Moved to SR-5(2).]

(8) SUPPLY CHAIN PROTECTION | USE OF ALL-SOURCE INTELLIGENCE
[Withdrawn: Incorporated into RA-3(2).]

(9) SUPPLY CHAIN PROTECTION | OPERATIONS SECURITY
[Withdrawn: Moved to SR-7.]

(10) SUPPLY CHAIN PROTECTION | VALIDATE AS GENUINE AND NOT ALTERED
[Withdrawn: Moved to SR-4(3).]

(11) SUPPLY CHAIN PROTECTION | PENETRATION TESTING / ANALYSIS OF ELEMENTS, PROCESSES, AND ACTORS
[Withdrawn: Moved to SR-6(1).]

(12) SUPPLY CHAIN PROTECTION | INTER-ORGANIZATIONAL AGREEMENTS
[Withdrawn: Moved to SR-8.]

(13) SUPPLY CHAIN PROTECTION | CRITICAL INFORMATION SYSTEM COMPONENTS
[Withdrawn: Incorporated into MA-6 and RA-9.]

(14) SUPPLY CHAIN PROTECTION | IDENTITY AND TRACEABILITY
[Withdrawn: Moved to SR-4(1) and SR-4(2).]

(15) SUPPLY CHAIN PROTECTION | PROCESSES TO ADDRESS WEAKNESSES OR DEFICIENCIES
[Withdrawn: Incorporated into SR-3.]

SA-13 TRUSTWORTHINESS

[Withdrawn: Incorporated into SA-8.]

This publication is available free of charge from: https://doi.org/10.6028/NIST.SP.800-53r5

SI-2 FLAW REMEDIATION

Control:

a. Identify, report, and correct system flaws;

b. Test software and firmware updates related to flaw remediation for effectiveness and potential side effects before installation;

c. Install security-relevant software and firmware updates within [*Assignment: organization-defined time period*] of the release of the updates; and

d. Incorporate flaw remediation into the organizational configuration management process.

Discussion: The need to remediate system flaws applies to all types of software and firmware. Organizations identify systems affected by software flaws, including potential vulnerabilities resulting from those flaws, and report this information to designated organizational personnel with information security and privacy responsibilities. Security-relevant updates include patches, service packs, and malicious code signatures. Organizations also address flaws discovered during assessments, continuous monitoring, incident response activities, and system error handling. By incorporating flaw remediation into configuration management processes, required remediation actions can be tracked and verified.

Organization-defined time periods for updating security-relevant software and firmware may vary based on a variety of risk factors, including the security category of the system, the criticality of the update (i.e., severity of the vulnerability related to the discovered flaw), the organizational risk tolerance, the mission supported by the system, or the threat environment. Some types of flaw remediation may require more testing than other types. Organizations determine the type of testing needed for the specific type of flaw remediation activity under consideration and the types of changes that are to be configuration-managed. In some situations, organizations may determine that the testing of software or firmware updates is not necessary or practical, such as when implementing simple malicious code signature updates. In testing decisions, organizations consider whether security-relevant software or firmware updates are obtained from authorized sources with appropriate digital signatures.

Related Controls: CA-5, CM-3, CM-4, CM-5, CM-6, CM-8, MA-2, RA-5, SA-8, SA-10, SA-11, SI-3, SI-5, SI-7, SI-11.

Control Enhancements:

(1) FLAW REMEDIATION | CENTRAL MANAGEMENT

[Withdrawn: Incorporated into PL-9.]

(2) FLAW REMEDIATION | AUTOMATED FLAW REMEDIATION STATUS

Determine if system components have applicable security-relevant software and firmware updates installed using [*Assignment: organization-defined automated mechanisms*] [*Assignment: organization-defined frequency*].

Discussion: Automated mechanisms can track and determine the status of known flaws for system components.

Related Controls: CA-7, SI-4.

(3) FLAW REMEDIATION | TIME TO REMEDIATE FLAWS AND BENCHMARKS FOR CORRECTIVE ACTIONS

(a) Measure the time between flaw identification and flaw remediation; and

(b) Establish the following benchmarks for taking corrective actions: [*Assignment: organization-defined benchmarks*].

Discussion: Organizations determine the time it takes on average to correct system flaws after such flaws have been identified and subsequently establish organizational benchmarks

This publication is available free of charge from: https://doi.org/10.6028/NIST.SP.800-53r5

(i.e., time frames) for taking corrective actions. Benchmarks can be established by the type of flaw or the severity of the potential vulnerability if the flaw can be exploited.

Related Controls: None.

(4) FLAW REMEDIATION | AUTOMATED PATCH MANAGEMENT TOOLS

Employ automated patch management tools to facilitate flaw remediation to the following system components: [*Assignment: organization-defined system components*].

Discussion: Using automated tools to support patch management helps to ensure the timeliness and completeness of system patching operations.

Related Controls: None.

(5) FLAW REMEDIATION | AUTOMATIC SOFTWARE AND FIRMWARE UPDATES

Install [*Assignment: organization-defined security-relevant software and firmware updates*] automatically to [*Assignment: organization-defined system components*].

Discussion: Due to system integrity and availability concerns, organizations consider the methodology used to carry out automatic updates. Organizations balance the need to ensure that the updates are installed as soon as possible with the need to maintain configuration management and control with any mission or operational impacts that automatic updates might impose.

Related Controls: None.

(6) FLAW REMEDIATION | REMOVAL OF PREVIOUS VERSIONS OF SOFTWARE AND FIRMWARE

Remove previous versions of [*Assignment: organization-defined software and firmware components*] after updated versions have been installed.

Discussion: Previous versions of software or firmware components that are not removed from the system after updates have been installed may be exploited by adversaries. Some products may automatically remove previous versions of software and firmware from the system.

Related Controls: None.

References: [OMB A-130], [FIPS 140-3], [FIPS 186-4], [SP 800-39], [SP 800-40], [SP 800-128], [IR 7788].

SI-3 MALICIOUS CODE PROTECTION

Control:

a. Implement [*Selection (one or more): signature based; non-signature based*] malicious code protection mechanisms at system entry and exit points to detect and eradicate malicious code;

b. Automatically update malicious code protection mechanisms as new releases are available in accordance with organizational configuration management policy and procedures;

c. Configure malicious code protection mechanisms to:

1. Perform periodic scans of the system [*Assignment: organization-defined frequency*] and real-time scans of files from external sources at [*Selection (one or more): endpoint; network entry and exit points*] as the files are downloaded, opened, or executed in accordance with organizational policy; and

2. [*Selection (one or more): block malicious code; quarantine malicious code; take* [*Assignment: organization-defined action*]]; and send alert to [*Assignment: organization-defined personnel or roles*] in response to malicious code detection; and

This publication is available free of charge from: https://doi.org/10.6028/NIST.SP.800-53r5

3.20 SUPPLY CHAIN RISK MANAGEMENT

Quick link to Supply Chain Risk Management Summary Table

SR-1 POLICY AND PROCEDURES

Control:

a. Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]:

   1. [*Selection (one or more): Organization-level; Mission/business process-level; System-level*] supply chain risk management policy that:

      (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and

      (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and

   2. Procedures to facilitate the implementation of the supply chain risk management policy and the associated supply chain risk management controls;

b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the supply chain risk management policy and procedures; and

c. Review and update the current supply chain risk management:

   1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and

   2. Procedures [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*].

Discussion: Supply chain risk management policy and procedures address the controls in the SR family as well as supply chain-related controls in other families that are implemented within systems and organizations. The risk management strategy is an important factor in establishing such policies and procedures. Policies and procedures contribute to security and privacy assurance. Therefore, it is important that security and privacy programs collaborate on the development of supply chain risk management policy and procedures. Security and privacy program policies and procedures at the organization level are preferable, in general, and may obviate the need for mission- or system-specific policies and procedures. The policy can be included as part of the general security and privacy policy or be represented by multiple policies that reflect the complex nature of organizations. Procedures can be established for security and privacy programs, for mission or business processes, and for systems, if needed. Procedures describe how the policies or controls are implemented and can be directed at the individual or role that is the object of the procedure. Procedures can be documented in system security and privacy plans or in one or more separate documents. Events that may precipitate an update to supply chain risk management policy and procedures include assessment or audit findings, security incidents or breaches, or changes in applicable laws, executive orders, directives, regulations, policies, standards, and guidelines. Simply restating controls does not constitute an organizational policy or procedure.

Related Controls: PM-9, PM-30, PS-8, SI-12.

Control Enhancements: None.

This publication is available free of charge from: https://doi.org/10.6028/NIST.SP.800-53r5

References: [FASC18], [41 CFR 201], [EO 13873], [CNSSD 505], [SP 800-12], [SP 800-30], [SP 800-39], [SP 800-100], [SP 800-161].

SR-2 SUPPLY CHAIN RISK MANAGEMENT PLAN

Control:

a. Develop a plan for managing supply chain risks associated with the research and development, design, manufacturing, acquisition, delivery, integration, operations and maintenance, and disposal of the following systems, system components or system services: [*Assignment: organization-defined systems, system components, or system services*];

b. Review and update the supply chain risk management plan [*Assignment: organization-defined frequency*] or as required, to address threat, organizational or environmental changes; and

c. Protect the supply chain risk management plan from unauthorized disclosure and modification.

Discussion: The dependence on products, systems, and services from external providers, as well as the nature of the relationships with those providers, present an increasing level of risk to an organization. Threat actions that may increase security or privacy risks include unauthorized production, the insertion or use of counterfeits, tampering, theft, insertion of malicious software and hardware, and poor manufacturing and development practices in the supply chain. Supply chain risks can be endemic or systemic within a system element or component, a system, an organization, a sector, or the Nation. Managing supply chain risk is a complex, multifaceted undertaking that requires a coordinated effort across an organization to build trust relationships and communicate with internal and external stakeholders. Supply chain risk management (SCRM) activities include identifying and assessing risks, determining appropriate risk response actions, developing SCRM plans to document response actions, and monitoring performance against plans. The SCRM plan (at the system-level) is implementation specific, providing policy implementation, requirements, constraints and implications. It can either be stand-alone, or incorporated into system security and privacy plans. The SCRM plan addresses managing, implementation, and monitoring of SCRM controls and the development/sustainment of systems across the SDLC to support mission and business functions.

Because supply chains can differ significantly across and within organizations, SCRM plans are tailored to the individual program, organizational, and operational contexts. Tailored SCRM plans provide the basis for determining whether a technology, service, system component, or system is fit for purpose, and as such, the controls need to be tailored accordingly. Tailored SCRM plans help organizations focus their resources on the most critical mission and business functions based on mission and business requirements and their risk environment. Supply chain risk management plans include an expression of the supply chain risk tolerance for the organization, acceptable supply chain risk mitigation strategies or controls, a process for consistently evaluating and monitoring supply chain risk, approaches for implementing and communicating the plan, a description of and justification for supply chain risk mitigation measures taken, and associated roles and responsibilities. Finally, supply chain risk management plans address requirements for developing trustworthy, secure, privacy-protective, and resilient system components and systems, including the application of the security design principles implemented as part of life cycle-based systems security engineering processes (see SA-8).

Related Controls: CA-2, CP-4, IR-4, MA-2, MA-6, PE-16, PL-2, PM-9, PM-30, RA-3, RA-7, SA-8, SI-4.

Control Enhancements:

(1) SUPPLY CHAIN RISK MANAGEMENT PLAN | ESTABLISH SCRM TEAM

This publication is available free of charge from: https://doi.org/10.6028/NIST.SP.800-53r5

TABLE C-7: IDENTIFICATION AND AUTHENTICATION FAMILY

CONTROL NUMBER	CONTROL NAME CONTROL ENHANCEMENT NAME	IMPLEMENTED BY	ASSURANCE
IA-1	**Policy and Procedures**	O	√
IA-2	**Identification and Authentication (Organizational Users)**	O/S	
IA-2(1)	MULTI-FACTOR AUTHENTICATION TO PRIVILEGED ACCOUNTS	S	
IA-2(2)	MULTI-FACTOR AUTHENTICATION TO NON-PRIVILEGED ACCOUNTS	S	
IA-2(3)	LOCAL ACCESS TO PRIVILEGED ACCOUNTS	W: Incorporated into IA-2(1).	
IA-2(4)	LOCAL ACCESS TO NON-PRIVILEGED ACCOUNTS	W: Incorporated into IA-2(2).	
IA-2(5)	INDIVIDUAL AUTHENTICATION WITH GROUP AUTHENTICATION	O/S	
IA-2(6)	ACCESS TO ACCOUNTS — SEPARATE DEVICE	S	
IA-2(7)	NETWORK ACCESS TO NON-PRIVILEGED ACCOUNTS — SEPARATE DEVICE	W: Incorporated into IA-2(6).	
IA-2(8)	ACCESS TO ACCOUNTS — REPLAY RESISTANT	S	
IA-2(9)	NETWORK ACCESS TO NON-PRIVILEGED ACCOUNTS — REPLAY RESISTANT	W: Incorporated into IA-2(8).	
IA-2(10)	SINGLE SIGN-ON	S	
IA-2(11)	REMOTE ACCESS — SEPARATE DEVICE	W: Incorporated into IA-2(6).	
IA-2(12)	ACCEPTANCE OF PIV CREDENTIALS	S	
IA-2(13)	OUT-OF-BAND AUTHENTICATION	S	
IA-3	**Device Identification and Authentication**	S	
IA-3(1)	CRYPTOGRAPHIC BIDIRECTIONAL AUTHENTICATION	S	
IA-3(2)	CRYPTOGRAPHIC BIDIRECTIONAL NETWORK AUTHENTICATION	W: Incorporated into IA-3(1).	
IA-3(3)	DYNAMIC ADDRESS ALLOCATION	O	
IA-3(4)	DEVICE ATTESTATION	O	
IA-4	**Identifier Management**	O	
IA-4(1)	PROHIBIT ACCOUNT IDENTIFIERS AS PUBLIC IDENTIFIERS	O	
IA-4(2)	SUPERVISOR AUTHORIZATION	W: Incorporated into IA-12(1).	
IA-4(3)	MULTIPLE FORMS OF CERTIFICATION	W: Incorporated into IA-12(2).	
IA-4(4)	IDENTIFY USER STATUS	O	
IA-4(5)	DYNAMIC MANAGEMENT	S	
IA-4(6)	CROSS-ORGANIZATION MANAGEMENT	O	
IA-4(7)	IN-PERSON REGISTRATION	W: Incorporated into IA-12(4).	
IA-4(8)	PAIRWISE PSEUDONYMOUS IDENTIFIERS	O	
IA-4(9)	ATTRIBUTE MAINTENANCE AND PROTECTION	O/S	
IA-5	**Authenticator Management**	O/S	
IA-5(1)	PASSWORD-BASED AUTHENTICATION	O/S	
IA-5(2)	PUBLIC KEY-BASED AUTHENTICATION	S	
IA-5(3)	IN-PERSON OR TRUSTED EXTERNAL PARTY REGISTRATION	W: Incorporated into IA-12(4).	
IA-5(4)	AUTOMATED SUPPORT FOR PASSWORD STRENGTH DETERMINATION	W: Incorporated into IA-5(1).	
IA-5(5)	CHANGE AUTHENTICATORS PRIOR TO DELIVERY	O	
IA-5(6)	PROTECTION OF AUTHENTICATORS	O	
IA-5(7)	NO EMBEDDED UNENCRYPTED STATIC AUTHENTICATORS	O	
IA-5(8)	MULTIPLE SYSTEM ACCOUNTS	O	
IA-5(9)	FEDERATED CREDENTIAL MANAGEMENT	O	
IA-5(10)	DYNAMIC CREDENTIAL BINDING	S	
IA-5(11)	HARDWARE TOKEN-BASED AUTHENTICATION	W: Incorporated into IA-2(1) and IA-2(2).	

This publication is available free of charge from: https://doi.org/10.6028/NIST.SP.800-53r5

CONTROL NUMBER	CONTROL NAME CONTROL ENHANCEMENT NAME	IMPLEMENTED BY	ASSURANCE
IA-5(12)	BIOMETRIC AUTHENTICATION PERFORMANCE	S	
IA-5(13)	EXPIRATION OF CACHED AUTHENTICATORS	S	
IA-5(14)	MANAGING CONTENT OF PKI TRUST STORES	O	
IA-5(15)	GSA-APPROVED PRODUCTS AND SERVICES	O	
IA-5(16)	IN-PERSON OR TRUSTED EXTERNAL PARTY AUTHENTICATOR ISSUANCE	O	
IA-5(17)	PRESENTATION ATTACK DETECTION FOR BIOMETRIC AUTHENTICATORS	S	
IA-5(18)	PASSWORD MANAGERS	S	
IA-6	**Authentication Feedback**	S	
IA-7	**Cryptographic Module Authentication**	S	
IA-8	**Identification and Authentication (Non-Organizational Users)**	S	
IA-8(1)	ACCEPTANCE OF PIV CREDENTIALS FROM OTHER AGENCIES	S	
IA-8(2)	ACCEPTANCE OF EXTERNAL AUTHENTICATORS	S	
IA-8(3)	USE OF FICAM-APPROVED PRODUCTS	W: Incorporated into IA-8(2).	
IA-8(4)	USE OF DEFINED PROFILES	S	
IA-8(5)	ACCEPTANCE OF PIV-I CREDENTIALS	S	
IA-8(6)	DISASSOCIABILITY	O	
IA-9	**Service Identification and Authentication**	O/S	
IA-9(1)	INFORMATION EXCHANGE	W: Incorporated into IA-9.	
IA-9(2)	TRANSMISSION OF DECISIONS	W: Incorporated into IA-9.	
IA-10	**Adaptive Authentication**	O	
IA-11	**Re-authentication**	O/S	
IA-12	**Identity Proofing**	O	
IA-12(1)	SUPERVISOR AUTHORIZATION	O	
IA-12(2)	IDENTITY EVIDENCE	O	
IA-12(3)	IDENTITY EVIDENCE VALIDATION AND VERIFICATION	O	
IA-12(4)	IN-PERSON VALIDATION AND VERIFICATION	O	
IA-12(5)	ADDRESS CONFIRMATION	O	
IA-12(6)	ACCEPT EXTERNALLY-PROOFED IDENTITIES	O	

This publication is available free of charge from: https://doi.org/10.6028/NIST.SP.800-53r5

TABLE C-17: SYSTEM AND SERVICES ACQUISITION FAMILY

CONTROL NUMBER	CONTROL NAME CONTROL ENHANCEMENT NAME	IMPLEMENTED BY	ASSURANCE
SA-1	**Policy and Procedures**	O	√
SA-2	**Allocation of Resources**	O	√
SA-3	**System Development Life Cycle**	O	√
SA-3(1)	MANAGE PREPRODUCTION ENVIRONMENT	O	√
SA-3(2)	USE OF LIVE OR OPERATIONAL DATA	O	√
SA-3(3)	TECHNOLOGY REFRESH	O	√
SA-4	**Acquisition Process**	O	√
SA-4(1)	FUNCTIONAL PROPERTIES OF CONTROLS	O	√
SA-4(2)	DESIGN AND IMPLEMENTATION INFORMATION FOR CONTROLS	O	√
SA-4(3)	DEVELOPMENT METHODS, TECHNIQUES, AND PRACTICES	O	√
SA-4(4)	ASSIGNMENT OF COMPONENTS TO SYSTEMS	W: Incorporated into CM-8(9).	
SA-4(5)	SYSTEM, COMPONENT, AND SERVICE CONFIGURATIONS	O	√
SA-4(6)	USE OF INFORMATION ASSURANCE PRODUCTS	O	√
SA-4(7)	NIAP-APPROVED PROTECTION PROFILES	O	√
SA-4(8)	CONTINUOUS MONITORING PLAN FOR CONTROLS	O	√
SA-4(9)	FUNCTIONS, PORTS, PROTOCOLS, AND SERVICES IN USE	O	√
SA-4(10)	USE OF APPROVED PIV PRODUCTS	O	√
SA-4(11)	SYSTEM OF RECORDS	O	√
SA-4(12)	DATA OWNERSHIP	O	√
SA-5	**System Documentation**	O	√
SA-5(1)	FUNCTIONAL PROPERTIES OF SECURITY CONTROLS	W: Incorporated into SA-4(1).	
SA-5(2)	SECURITY-RELEVANT EXTERNAL SYSTEM INTERFACES	W: Incorporated into SA-4(2).	
SA-5(3)	HIGH-LEVEL DESIGN	W: Incorporated into SA-4(2).	
SA-5(4)	LOW-LEVEL DESIGN	W: Incorporated into SA-4(2).	
SA-5(5)	SOURCE CODE	W: Incorporated into SA-4(2).	
SA-6	**Software Usage Restrictions**	W: Incorporated into CM-10 and SI-7.	
SA-7	**User-Installed Software**	W: Incorporated into CM-11 and SI-7.	
SA-8	**Security and Privacy Engineering Principles**	O	√
SA-8(1)	CLEAR ABSTRACTIONS	O/S	√
SA-8(2)	LEAST COMMON MECHANISM	O/S	√
SA-8(3)	MODULARITY AND LAYERING	O/S	√
SA-8(4)	PARTIALLY ORDERED DEPENDENCIES	O/S	√
SA-8(5)	EFFICIENTLY MEDIATED ACCESS	O/S	√
SA-8(6)	MINIMIZED SHARING	O/S	√
SA-8(7)	REDUCED COMPLEXITY	O/S	√
SA-8(8)	SECURE EVOLVABILITY	O/S	√
SA-8(9)	TRUSTED COMPONENTS	O/S	√
SA-8(10)	HIERARCHICAL TRUST	O/S	√
SA-8(11)	INVERSE MODIFICATION THRESHOLD	O/S	√
SA-8(12)	HIERARCHICAL PROTECTION	O/S	√
SA-8(13)	MINIMIZED SECURITY ELEMENTS	O/S	√
SA-8(14)	LEAST PRIVILEGE	O/S	√

This publication is available free of charge from: https://doi.org/10.6028/NIST.SP.800-53r5

CONTROL NUMBER	CONTROL NAME CONTROL ENHANCEMENT NAME	IMPLEMENTED BY	ASSURANCE
SA-8(15)	PREDICATE PERMISSION	O/S	V
SA-8(16)	SELF-RELIANT TRUSTWORTHINESS	O/S	V
SA-8(17)	SECURE DISTRIBUTED COMPOSITION	O/S	V
SA-8(18)	TRUSTED COMMUNICATIONS CHANNELS	O/S	V
SA-8(19)	CONTINUOUS PROTECTION	O/S	V
SA-8(20)	SECURE METADATA MANAGEMENT	O/S	V
SA-8(21)	SELF-ANALYSIS	O/S	V
SA-8(22)	ACCOUNTABILITY AND TRACEABILITY	O/S	V
SA-8(23)	SECURE DEFAULTS	O/S	V
SA-8(24)	SECURE FAILURE AND RECOVERY	O/S	V
SA-8(25)	ECONOMIC SECURITY	O/S	V
SA-8(26)	PERFORMANCE SECURITY	O/S	V
SA-8(27)	HUMAN FACTORED SECURITY	O/S	V
SA-8(28)	ACCEPTABLE SECURITY	O/S	V
SA-8(29)	REPEATABLE AND DOCUMENTED PROCEDURES	O/S	V
SA-8(30)	PROCEDURAL RIGOR	O/S	V
SA-8(31)	SECURE SYSTEM MODIFICATION	O/S	V
SA-8(32)	SUFFICIENT DOCUMENTATION	O/S	V
SA-8(33)	MINIMIZATION	O/S	V
SA-9	**External System Services**	O	V
SA-9(1)	RISK ASSESSMENTS AND ORGANIZATIONAL APPROVALS	O	V
SA-9(2)	IDENTIFICATION OF FUNCTIONS, PORTS, PROTOCOLS, AND SERVICES	O	V
SA-9(3)	ESTABLISH AND MAINTAIN TRUST RELATIONSHIP WITH PROVIDERS	O	V
SA-9(4)	CONSISTENT INTERESTS OF CONSUMERS AND PROVIDERS	O	V
SA-9(5)	PROCESSING, STORAGE, AND SERVICE LOCATION	O	V
SA-9(6)	ORGANIZATION-CONTROLLED CRYPTOGRAPHIC KEYS	O	V
SA-9(7)	ORGANIZATION-CONTROLLED INTEGRITY CHECKING	O	V
SA-9(8)	PROCESSING AND STORAGE LOCATION — U.S. JURISDICTION	O	V
SA-10	**Developer Configuration Management**	O	V
SA-10(1)	SOFTWARE AND FIRMWARE INTEGRITY VERIFICATION	O	V
SA-10(2)	ALTERNATIVE CONFIGURATION MANAGEMENT PROCESSES	O	V
SA-10(3)	HARDWARE INTEGRITY VERIFICATION	O	V
SA-10(4)	TRUSTED GENERATION	O	V
SA-10(5)	MAPPING INTEGRITY FOR VERSION CONTROL	O	V
SA-10(6)	TRUSTED DISTRIBUTION	O	V
SA-10(7)	SECURITY AND PRIVACY REPRESENTATIVES	O	V
SA-11	**Developer Testing and Evaluation**	O	V
SA-11(1)	STATIC CODE ANALYSIS	O	V
SA-11(2)	THREAT MODELING AND VULNERABILITY ANALYSES	O	V
SA-11(3)	INDEPENDENT VERIFICATION OF ASSESSMENT PLANS AND EVIDENCE	O	V
SA-11(4)	MANUAL CODE REVIEWS	O	V
SA-11(5)	PENETRATION TESTING	O	V
SA-11(6)	ATTACK SURFACE REVIEWS	O	V

This publication is available free of charge from: https://doi.org/10.6028/NIST.SP.800-53r5

CONTROL NUMBER	CONTROL NAME CONTROL ENHANCEMENT NAME	IMPLEMENTED BY	ASSURANCE
SA-11(7)	VERIFY SCOPE OF TESTING AND EVALUATION	O	√
SA-11(8)	DYNAMIC CODE ANALYSIS	O	√
SA-11(9)	INTERACTIVE APPLICATION SECURITY TESTING	O	√
SA-12	**Supply Chain Protection**	W: Moved to SR Family.	
SA-12(1)	ACQUISITION STRATEGIES, TOOLS, AND METHODS	W: Moved to SR-5.	
SA-12(2)	SUPPLIER REVIEWS	W: Moved to SR-6.	
SA-12(3)	TRUSTED SHIPPING AND WAREHOUSING	W: Incorporated into SR-3.	
SA-12(4)	DIVERSITY OF SUPPLIERS	W: Moved to SR-3(1).	
SA-12(5)	LIMITATION OF HARM	W: Moved to SR-3(2).	
SA-12(6)	MINIMIZING PROCUREMENT TIME	W: Incorporated into SR-5(1).	
SA-12(7)	ASSESSMENTS PRIOR TO SELECTION / ACCEPTANCE / UPDATE	W: Moved to SR-5(2).	
SA-12(8)	USE OF ALL-SOURCE INTELLIGENCE	W: Incorporated into RA-3(2).	
SA-12(9)	OPERATIONS SECURITY	W: Moved to SR-7.	
SA-12(10)	VALIDATE AS GENUINE AND NOT ALTERED	W: Moved to SR-4(3).	
SA-12(11)	PENETRATION TESTING / ANALYSIS OF ELEMENTS, PROCESSES, AND ACTORS	W: Moved to SR-6(1).	
SA-12(12)	INTER-ORGANIZATIONAL AGREEMENTS	W: Moved to SR-8.	
SA-12(13)	CRITICAL INFORMATION SYSTEM COMPONENTS	W: Incorporated into MA-6 and RA-9.	
SA-12(14)	IDENTITY AND TRACEABILITY	W: Moved to SR-4(1) and SR-4(2).	
SA-12(15)	PROCESSES TO ADDRESS WEAKNESSES OR DEFICIENCIES	W: Incorporated into SR-3.	
SA-13	**Trustworthiness**	W: Incorporated into SA-8.	
SA-14	**Criticality Analysis**	W: Incorporated into RA-9.	
SA-14(1)	CRITICAL COMPONENTS WITH NO VIABLE ALTERNATIVE SOURCING	W: Incorporated into SA-20.	
SA-15	**Development Process, Standards, and Tools**	O	√
SA-15(1)	QUALITY METRICS	O	√
SA-15(2)	SECURITY AND PRIVACY TRACKING TOOLS	O	√
SA-15(3)	CRITICALITY ANALYSIS	O	√
SA-15(4)	THREAT MODELING AND VULNERABILITY ANALYSIS	W: Incorporated into SA-11(2).	
SA-15(5)	ATTACK SURFACE REDUCTION	O	√
SA-15(6)	CONTINUOUS IMPROVEMENT	O	√
SA-15(7)	AUTOMATED VULNERABILITY ANALYSIS	O	√
SA-15(8)	REUSE OF THREAT AND VULNERABILITY INFORMATION	O	√
SA-15(9)	USE OF LIVE DATA	W: Incorporated into SA-3(2).	
SA-15(10)	INCIDENT RESPONSE PLAN	O	√
SA-15(11)	ARCHIVE SYSTEM OR COMPONENT	O	√
SA-15(12)	MINIMIZE PERSONALLY IDENTIFIABLE INFORMATION	O	√
SA-16	**Developer-Provided Training**	O	√
SA-17	**Developer Security and Privacy Architecture and Design**	O	√
SA-17(1)	FORMAL POLICY MODEL	O	√
SA-17(2)	SECURITY-RELEVANT COMPONENTS	O	√
SA-17(3)	FORMAL CORRESPONDENCE	O	√
SA-17(4)	INFORMAL CORRESPONDENCE	O	√
SA-17(5)	CONCEPTUALLY SIMPLE DESIGN	O	√

This publication is available free of charge from: https://doi.org/10.6028/NIST.SP.800-53r5

CONTROL NUMBER	CONTROL NAME CONTROL ENHANCEMENT NAME	IMPLEMENTED BY	ASSURANCE
SA-17(6)	STRUCTURE FOR TESTING	O	√
SA-17(7)	STRUCTURE FOR LEAST PRIVILEGE	O	√
SA-17(8)	ORCHESTRATION	O	√
SA-17(9)	DESIGN DIVERSITY	O	√
SA-18	**Tamper Resistance and Detection**	W: Moved to SR-9.	
SA-18(1)	MULTIPLE PHASES OF SYSTEM DEVELOPMENT LIFE CYCLE	W: Moved to SR-9(1).	
SA-18(2)	INSPECTION OF SYSTEMS OR COMPONENTS	W: Moved to SR-10.	
SA-19	**Component Authenticity**	W: Moved to SR-11.	
SA-19(1)	ANTI-COUNTERFEIT TRAINING	W: Moved to SR-11(1).	
SA-19(2)	CONFIGURATION CONTROL FOR COMPONENT SERVICE AND REPAIR	W: Moved to SR-11(2).	
SA-19(3)	COMPONENT DISPOSAL	W: Moved to SR-12.	
SA-19(4)	ANTI-COUNTERFEIT SCANNING	W: Moved to SR-11(3).	
SA-20	**Customized Development of Critical Components**	O	√
SA-21	**Developer Screening**	O	√
SA-21(1)	VALIDATION OF SCREENING	W: Incorporated into SA-21.	
SA-22	**Unsupported System Components**	O	√
SA-22(1)	ALTERNATIVE SOURCES FOR CONTINUED SUPPORT	W: Incorporated into SA-22.	
SA-23	**Specialization**	O	√

This publication is available free of charge from: https://doi.org/10.6028/NIST.SP.800-53r5